

MyGymBro

Bug, Backend & Security Audit

v2 — post-remediation • 2026-07-07

Records the fixes applied this session and what remains before deployment. Supersedes the initial audit.

Executive Summary

A remediation pass has been completed. **Eleven code-level issues are now fixed** across the edge functions, Supabase schema/RLS, and the sync layer: push migrated to the current FCM v1 API, the RevenueCat webhook auth corrected, account deletion made real and transactional, the payroll data bypass locked at the column level, the broken reminders and the challenge-spam vector fixed, service-role env var corrected, cron scheduling added, grace-period honoured, and the sync injection sink guarded.

Correction: the first draft listed two sync bugs (a re-injected `remote_id` and a `total_volume` column mismatch) as fixed. On verification **neither bug existed** — the code already strips `remote_id` and already writes `total_volume_kg`. Those claims are retracted; nothing was broken and nothing needed changing there.

What remains is **deployment configuration** (setting secrets, applying migrations, wiring the FCM service account and RevenueCat dashboard secret — no code) plus **two deliberate holds**: the **S1 dev "Skip" backdoor**, left in at the owner's request and which **MUST** be removed before release, and **S6 paid-skin server verification**, which needs store IAP products before it can be finished.

11 Fixed in code	2 False bugs retracted	1 Intentional hold (S1)	1 Needs store IAP (S6)	Config deploy actions left
----------------------------	----------------------------------	-----------------------------------	----------------------------------	--------------------------------------

Legend: **FIXED** / **PASS** • **CONFIG** (deploy action) • **INTENTIONAL** • **HIGH** • **MEDIUM**

1. Fixed This Session (code)

Status	Item	What changed
FIXED	A — Push migrated to FCM v1	New shared OAuth2 sender (<code>_shared/fcm.ts</code>) mints a token from a service-account key and posts to <code>/v1/projects/.../messages:send</code> . All three push functions rewired; dead-token pruning added. Requires the new <code>FCM_SERVICE_ACCOUNT</code> secret (see §3).
FIXED	B — RevenueCat webhook auth	Replaced the HMAC check (which rejected every real event) with a constant-time compare of the Authorization header against <code>REVENUECAT_WEBHOOK_SECRET</code> — how RevenueCat actually authenticates. Subscriptions will now activate.
FIXED	C — Delete Account truly deletes	New transactional <code>delete_account_data()</code> (migration 009) hard-deletes all of a user's rows in FK-safe order; the function calls it, then <code>deleteUser</code> , and now returns an error instead of silently swallowing a failed deletion. Closes the store/GDPR gap.

Status	Item	What changed
FIXED	D / S2 — Paywall data bypass	Migration 009 REVOKES UPDATE/INSERT on user_profiles and GRANTs back only the safe, user-editable columns — clients can no longer set subscription_status='active'. Verified the app only syncs notification_tone, so nothing breaks.
FIXED	E — Broken training reminders	schedule-notifications no longer queries the nonexistent day_of_week column; reminders now target active-schedule users who haven't trained today/recently (rotation model has no server-side weekday). Morning/evening/streak all send again.
FIXED	F / S5 — Challenge push spam	notify-social-challenge now fires only for the caller's OWN PR, uses the server-side display name (not client text), sanitizes the exercise label, and notifies only the user's followers instead of the whole user base.
FIXED	G — Service-role env var	All functions now read SUPABASE_SERVICE_ROLE_KEY (auto-injected) instead of an unset SERVICE_ROLE_KEY.
FIXED	H — Cron scheduling	Migration 010 schedules compute-leaderboard and schedule-notifications hourly via pg_cron/pg_net, reading the URL + cron secret from Vault (no secrets committed). Leaderboard/ranks populate once the operator adds the two vault secrets.
FIXED	I — grace_period counts active	has_active_subscription (009) now treats 'grace_period' as active, so billing-retry users keep access.
FIXED	S3 — Push endpoints gated	send-push-notification and schedule-notifications require the CRON_SECRET header (verified present after the rewrite). No longer callable by arbitrary clients.
FIXED	S7 — Sync injection sink	sync_service now rejects any table name that isn't lowercase snake_case before interpolating it into raw SQL. 117/117 tests green.
FIXED	Ranks + skins UI (earlier)	Rivals tier mapping, Home fake-avatar data, locale volume formatting, owned-skins load race, and the Rivals RPC join — all fixed earlier this session.

2. Remaining Before Launch

Status	Item	Detail
INTENTIONAL	S1 — dev "Skip" backdoor	Left in at the owner's request to keep opening the app during development. It bypasses auth and reaches gated content. Must be removed (or compiled out of release builds) before store submission — it is a hard blocker the moment you ship.
MEDIUM	S6 — paid-skin verification	Paid-skin ownership is still local-only (forgeable, lost on reinstall). Needs RevenueCat one-time products + a purchase-skin verify function + a skin_ownership table + Restore Purchases before real skin sales can be enabled. Progress skins (earned by workouts) are fine as-is.
CONFIG	Set edge-function secrets	FCM_SERVICE_ACCOUNT (service-account JSON), CRON_SECRET, REVENUECAT_WEBHOOK_SECRET (= the exact Authorization value in the RevenueCat dashboard). No code — project settings.
CONFIG	Apply migrations + vault	Push migrations 006-010 to the cloud project, then add the two Vault secrets project_url and cron_secret (010's header lists the exact commands) so the cron jobs can call the functions.
CONFIG	APNs / FCM + RevenueCat setup	Firebase project + APNs key for iOS push; RevenueCat dashboard webhook Authorization header; production subscription products. (Blocked on the Apple Developer account.)
LOW	Artwork + I10n backfill	Drop the 15 rank badge PNGs into assets/badges/ (fallback medals render until then); backfill the ~58 missing de/es/fr localization keys.

3. Security Posture (updated)

Status	Finding	Note
FIXED	S2 Paywall RLS bypass	Column-level GRANT (009).
FIXED	S3 Open push endpoints	CRON_SECRET gate.
FIXED	S4 Webhook auth	Constant-time secret compare.
FIXED	S5 Challenge broadcast	Identity + sanitize + follower-scoped.
FIXED	S7 SQL interpolation	snake_case identifier guard.
INTENTIONAL	S1 Auth Skip bypass	Open by owner's choice for dev; remove before release.
MEDIUM	S6 Forgeable paid skins	Needs server-side purchase verification (store IAP).
PASS	Secrets / logging / storage / input / RLS	Unchanged and passing: no secrets in repo, PII log scrubbing, secure token storage, input sanitization, RLS on every table.

4. Deployment Checklist (operator actions)

- Create a Firebase service account key; set it as the FCM_SERVICE_ACCOUNT secret on the edge functions.
- Set CRON_SECRET (functions) and add matching Vault secret cron_secret + project_url (migration 010).
- Set REVENUECAT_WEBHOOK_SECRET to the exact Authorization header value configured in RevenueCat.
- Deploy the updated edge functions and push migrations 006-010 to the cloud project.
- Remove the S1 "Skip" button from release builds.

- Before enabling paid skins: create RevenueCat one-time products, build purchase-skin + skin_ownership, wire Restore.
- Add the 15 badge PNGs; backfill de/es/fr strings.
- On-device smoke test: push delivery, subscription activate via webhook, delete-account round-trip, offline sync.

5. Test & Release Hygiene

The most important lesson from this audit: the update-sync path had **no test coverage**, which is precisely why two non-bugs were reported as real in the first draft — with nothing exercising the code, working logic and broken logic looked identical on inspection. That gap is now closed. The suite went from 117 to **135 passing tests**; the items below record what was implemented and what still remains.

Implemented this session

Status	Item	What was done
FIXED	Sync guard + remote_id	test/sync_service_test.dart covers the two seams on the previously-untested path: the snake_case table-name guard (rejects uppercase / SQL / hyphen / digit / empty) and remote_id stripping (removed before any payload reaches PostgREST). The two unnecessary-break nits in that file were also cleared.
FIXED	Subscription gate	test/subscription_gate_test.dart — 8 cases across null-profile, active, expired, trial (future / past / null expiry), grace_period, and unknown status.
FIXED	Skin unlock gating	test/skin_unlock_test.dart — 6 cases via an extracted pure computeUnlockedSkinIds(); free / progress-threshold / paid-ownership resolution against the real skin catalog.
FIXED	CI already complete	Verified .github/workflows/ci.yml already runs analyze + test + a release build on main — no change needed. (An earlier automated edit that removed the build job was reverted.)
FIXED	Debug feed fallback removed	Dropped the kDebugMode sample-post injection in community_repository.dart; an empty feed now shows a genuine empty state in every build. The real offline MockCommunityRepository fallback is kept.
FIXED	Delete-account verify script	tool/verify_delete_account.py (mirrors the existing verify_* scripts) seeds every table delete_account_data() purges, calls the RPC, and asserts zero rows + the auth user is gone.

Still outstanding

Priority	Item	Detail
MEDIUM	Leaderboard scoring test	The Dart rank-band mapping is covered (rank_test.dart); the SQL side — compute_leaderboard_scores() percentile normalization — still needs a test against a local Supabase instance.
MEDIUM	Run the delete verify	The script exists but must be executed against local Supabase and pass before launch (it can't run in this environment).
MEDIUM	Public-profile screen	A PublicProfile model + provider exist but there is no profile screen , so "tap a feed / leaderboard row -> profile + FollowButton" is a feature to build, tracked separately — not folded into this pass to avoid scope creep.
LOW	Real community images	Replace the placeholder assets/images/sample_post_*.jpg with real content (your assets).
LOW	_showRestSheet nit	Left untouched: it lives in active_session_screen.dart, which is actively being edited. Clear the unused-element warning once that work lands.

Code changes this session: supabase/functions/_shared/fcm.ts (new), send-push-notification, schedule-notifications, notify-social-challenge, revenuecat-webhook, delete-account, compute-leaderboard, verify-subscription; migrations 009_security_hardening.sql and 010_cron_schedules.sql (new); lib/core/services/sync_service.dart. Edge functions and SQL were reviewed statically (no Deno/live DB here) — verify against the cloud project on deploy. Dart: flutter analyze clean on changed files, 117/117 tests pass.